

MediConnect — REST API Reference

Document version: 1.0 · Last updated: 2026-05-11

This is the contract reference for the MediConnect backend, intended for the API testing team. All endpoints listed are live on the deployed environment unless noted.

1. Environment

	Value
Base URL	https://mediconnect-production-c233.up.railway.app
Content-Type	application/json
Charset	UTF-8
CORS	Allowed origin patterns: http://localhost:* , https://*.netlify.app , https://*.up.railway.app (irrelevant for REST Assured / Postman)

The free Railway tier can cold-start (5–10 s on first request after idle). Set client timeouts ≥ 30 s.

2. Authentication

The API uses **JWT bearer tokens** issued by `/api/auth/login` (or `/api/admin/login`).

2.1 Login flow

POST `/api/auth/login`
Content-Type: `application/json`

```
{
  "email": "arun.kumar@cgh.com",
  "password": "MediConnect@123"
}
```

200 OK

```
{
  "userId": 3,
  "uniqueId": "DR-0001",
  "name": "Dr. Arun Kumar",
  "email": "arun.kumar@cgh.com",
  "role": "DOCTOR",
  "token": "eyJhbGciOiJIUzI1NiJ9..."
}
```

2.2 Using the token

Attach to every authenticated request:

Authorization: Bearer `eyJhbGciOiJIUzI1NiJ9...`

Tokens expire after **24 hours** (`jwt.expiration=86400000`).

2.3 Role tags used in this doc

Tag	Meaning
 Public	No token required
 AUTH	Any authenticated user (PATIENT, DOCTOR, or ADMIN)
 DOCTOR+	DOCTOR or ADMIN
 ADMIN	ADMIN only
 PT/DR/AD	PATIENT, DOCTOR or ADMIN (read endpoints in role-gated modules)

A missing/invalid token returns **401**; a token whose role doesn't match the endpoint returns **403**.

3. Seeded Test Data

The database is seeded with predictable users and IDs by `DataSeederApplication` . Every seeded user shares the password `MediConnect@123` .

Users / login credentials

Role	Name	Email	userId	Hospital
ADMIN	Admin Rajan	admin.rajan@cgh.com	1	City General
ADMIN	Admin Priya	admin.priya@amc.com	2	Apollo Medical
DOCTOR	Dr. Arun Kumar	arun.kumar@cgh.com	3	City General (Cardiology)
DOCTOR	Dr. Meena Reddy	meena.reddy@cgh.com	4	City General (Neurology)
DOCTOR	Dr. Vikram Singh	vikram.singh@amc.com	5	Apollo Medical (Orthopedics)
DOCTOR	Dr. Lakshmi Nair	lakshmi.nair@amc.com	6	Apollo Medical (Pediatrics)
PATIENT	Rajesh Sharma	rajesh.sharma@gmail.com	7	—
PATIENT	Sneha Patel	sneha.patel@gmail.com	8	—
PATIENT	Mohan Das	mohan.das@gmail.com	9	—
PATIENT	Anitha Krishnan	anitha.k@gmail.com	10	—

Reference IDs

Entity	IDs
Hospital	1 = City General, 2 = Apollo Medical
Department	1 = Cardiology, 2 = Neurology, 3 = Orthopedics, 4 = Pediatrics
Patient	1 = Rajesh, 2 = Sneha, 3 = Mohan, 4 = Anitha
Doctor	1 = Arun, 2 = Meena, 3 = Vikram, 4 = Lakshmi

Re-seeding (`DataSeederApplication`) wipes & re-inserts everything. Don't run it against a production-style DB without confirming.

4. Standard Response Patterns

Status	Meaning
200 OK	Successful GET / PUT / PATCH
201 Created	Successful POST creating a resource
204 No Content	Successful DELETE
400 Bad Request	Validation failure (e.g. missing required field)
401 Unauthorized	Missing / invalid / expired token
403 Forbidden	Authenticated but wrong role
404 Not Found	Resource ID doesn't exist
409 Conflict	Business rule violation (e.g. duplicate email on register)
500 Internal Server Error	Unhandled exception

Validation errors return an `ErrorResponseDTO` array: `[ { field, message, code } ]`.

5. Endpoints

5.1 Auth — `/api/auth`

POST `/api/auth/register` 

Register a new patient / doctor.

Body

```
{
  "firstName": "John",
  "lastName": "Doe",
  "email": "john.doe@gmail.com",
  "password": "Password@123",
  "phone": "9999999999",
  "role": "PATIENT",
  "dateOfBirth": "1995-05-10",
  "bloodGroup": "O+",
  "gender": "MALE",
  "specialization": null,
  "hospitalId": null
}
```

- `role` ∈ `PATIENT`, `DOCTOR`, `ADMIN`
- `specialization` & `hospitalId` are required when `role=DOCTOR`

Response 200 — `LoginResponse` shape (see §2.1).

POST `/api/auth/login` 

See §2.1.

5.2 Admin Auth — /api/admin

POST /api/admin/login 

Same shape as /api/auth/login but **only admins** may log in here.

POST /api/admin/register 

Register a new admin user. Body = RegisterRequest with role: "ADMIN" .

5.3 Admin Dashboard — /api/admin/**

All endpoints require **ADMIN** role.

Method	Path	Notes
GET	/api/admin/{id}/dashboard-stats	Per-admin landing page metrics
GET	/api/admin/stats	Global KPIs — totalHospitals , totalPatients , totalDoctors , totalAppointments , totalInventoryItems , totalBeds , occupiedBeds , icuOccupancyPct , doctorsOnDuty , newPatientsThisMonth , confirmed/pending/cancelled/completed Appointments
GET	/api/admin/bed-occupancy	Per-hospital bed grid
GET	/api/admin/appointment-stats	Appointment counts by status/type
GET	/api/admin/inventory-alerts	Items below reorder level
GET	/api/admin/lab-stats	Lab report KPIs
GET	/api/admin/bills	All bills with patient/appointment refs
GET	/api/admin/doctor-availability	All doctors + current status
GET	/api/admin/video-appointments	Online consults across all doctors
GET	/api/admin/analytics?hospitalId={id?}&department={name?}&rangeDays=180	Trend data for charts

5.4 Hospitals — /api/hospitals

Method	Path	Auth	Notes
GET	/api/hospitals	 Public	List all
GET	/api/hospitals/{id}	 Public	One hospital
POST	/api/hospitals	 AUTH	Create
PUT	/api/hospitals/{id}	 AUTH	Update
DELETE	/api/hospitals/{id}	 AUTH	Delete

Hospital body

```
{
  "hospitalName": "City General Hospital",
  "address": "12 MG Road",
  "city": "Chennai",
  "phone": "044-22001100",
  "totalBeds": 300,
  "availableBeds": 85,
  "emailCode": "CGH"
}
```

5.5 Doctors — /api/doctors

Method	Path	Auth	Notes
GET	/api/doctors	PT/DR/AD	List all
GET	/api/doctors/{id}	PT/DR/AD	One
GET	/api/doctors/hospital/{hospitalId}	PT/DR/AD	By hospital
GET	/api/doctors/specialization/{name}	PT/DR/AD	By specialization
GET	/api/doctors/{doctorId}/patients	PT/DR/AD	Patient roster
GET	/api/doctors/available?specialization=X&date=YYYY-MM-DD&time=HH:mm	PT/DR/AD	Find available
GET	/api/doctors/{id}/available-slots?date=YYYY-MM-DD	PT/DR/AD	Returns { availableSlots: ["09:00","09:30",...] }
POST	/api/doctors	DOCTOR+	Create
PUT	/api/doctors/{id}	DOCTOR+	Update
PATCH	/api/doctors/{id}/status	DOCTOR+	Body: { "status": "AVAILABLE" } (AVAILABLE / NOT_AVAILABLE)
DELETE	/api/doctors/{id}	DOCTOR+	

5.6 Patients — /api/patients PT/DR/AD

Method	Path	Notes
GET	/api/patients	All
GET	/api/patients/{id}	One
GET	/api/patients/by-user/{userId}	Look up patient via their userId (used after login)
GET	/api/patients/{id}/vitals	List vitals history
POST	/api/patients/{id}/vitals	Body: { "bp":"120/80", "heartRate":72, "glucose":95.0, "bmi":22.5 }
GET	/api/patients/{id}/medicines	Active medications

Method	Path	Notes
POST	/api/patients/{id}/medicines	Body: { "medicineName": "Amlodipine", "dosage": "5mg", "frequency": "Once daily", "scheduledTime": "8:00 AM", "st
GET	/api/patients/{id}/activities	Recent activity feed
POST	/api/patients	Create
PUT	/api/patients/{id}	Update
DELETE	/api/patients/{id}	Delete

5.7 Appointments — /api/appointments AUTH

Method	Path	Notes
GET	/api/appointments	Scope auto-filtered: PATIENT→own, DOCTOR→own, ADMIN→all
GET	/api/appointments/{id}	
GET	/api/appointments/patient/{patientId}	
GET	/api/appointments/doctor/{doctorId}	
POST	/api/appointments	Create
PUT	/api/appointments/{id}	Update
DELETE	/api/appointments/{id}	Cancel. PATIENT can only delete own; DOCTOR/ADMIN any

Appointment body

```
{
  "patient": { "patientId": 1 },
  "doctor": { "doctorId": 1 },
  "hospital": { "hospitalId": 1 },
  "appointmentDate": "2026-05-20",
  "appointmentTime": "10:00:00",
  "status": "SCHEDULED",
  "appointmentType": "IN_PERSON",
  "sessionUrl": null,
  "notes": null
}
```

- status ∈ SCHEDULED , COMPLETED , CANCELLED
- appointmentType ∈ IN_PERSON , ONLINE , VIDEO

5.8 Medical Records — /api/medical-records AUTH

Method	Path	Notes
GET	/api/medical-records	Scope auto-filtered as in appointments
GET	/api/medical-records/{id}	
GET	/api/medical-records/patient/{patientId}	
GET	/api/medical-records/doctor/{doctorId}	
POST	/api/medical-records	Create
PUT	/api/medical-records/{id}	Update

Method	Path	Notes
DELETE	/api/medical-records/{id}	

MedicalRecord body

```
{
  "patient": { "patientId": 1 },
  "doctor": { "doctorId": 1 },
  "hospital": { "hospitalId": 1 },
  "recordDate": "2026-05-08",
  "diagnosis": "Hypertension Stage 1",
  "treatment": "Lifestyle modification + Amlodipine",
  "prescription": "Amlodipine 5mg OD",
  "notes": "BP improved at follow-up.",
  "consultationType": "IN_PERSON"
}
```

5.9 Lab Reports — /api/lab-reports AUTH

Method	Path	Auth	Notes
GET	/api/lab-reports		Scope auto-filtered
GET	/api/lab-reports/{id}		
GET	/api/lab-reports/patient/{patientId}		
POST	/api/lab-reports		Create
PUT	/api/lab-reports/{id}		Update full record
PATCH	/api/lab-reports/{id}/result	ADMIN only	Body: { "result": "...", "isAbnormal": true }
DELETE	/api/lab-reports/{id}		

LabReport body

```
{
  "patient": { "patientId": 1 },
  "doctor": { "doctorId": 1 },
  "hospital": { "hospitalId": 1 },
  "testName": "Lipid Profile",
  "result": "LDL 140 mg/dL – Borderline High",
  "reportUrl": "https://reports.mediconnect.com/lab/1002.pdf",
  "reportDate": "2026-04-15",
  "isAbnormal": true
}
```

5.10 Beds — /api/beds AUTH

Method	Path	Notes
GET	/api/beds	All
GET	/api/beds/{id}	One
GET	/api/beds/hospital/{hospitalId}	By hospital
GET	/api/beds/status/{status}	Status ∈ OCCUPIED , AVAILABLE

Method	Path	Notes
POST	/api/beds	Create
PUT	/api/beds/{id}	Update
DELETE	/api/beds/{id}	

Bed body

```
{
  "hospital": { "hospitalId": 1 },
  "ward": "ICU",
  "bedNumber": 201,
  "status": "AVAILABLE",
  "patient": null
}
```

5.11 Inventory — /api/inventory AUTH

Method	Path	Notes
GET	/api/inventory	All
GET	/api/inventory/hospital/{hospitalId}	By hospital
POST	/api/inventory	Create
PUT	/api/inventory/{id}	Update
DELETE	/api/inventory/{id}	

Inventory body

```
{
  "hospital": { "hospitalId": 1 },
  "itemName": "Surgical Gloves (Box)",
  "category": "Consumables",
  "quantity": 500,
  "reorderLevel": 100
}
```

5.12 Notifications — /api/notifications AUTH

Method	Path	Notes
GET	/api/notifications/user/{userId}	All for user
GET	/api/notifications/user/{userId}/unread	Only unread
POST	/api/notifications	Create
PATCH	/api/notifications/{id}/read	Mark single as read
PUT	/api/notifications/read-all/{userId}	Mark all read
PUT	/api/notifications/{id}	Full update
DELETE	/api/notifications/{id}	

Notification body


```
{
  "user": { "userId": 7 },
  "notificationType": "APPOINTMENT",
  "message": "Your appointment is confirmed.",
  "isRead": false
}
```

- notificationType ∈ APPOINTMENT , LAB_REPORT , REMINDER

5.13 Prescriptions — /api/prescriptions

Method	Path	Auth
GET	/api/prescriptions/patient/{patientId}	PT/DR/AD
GET	/api/prescriptions/medical-record/{recordId}	PT/DR/AD
GET	/api/prescriptions/doctor/{doctorId}	DOCTOR+
POST	/api/prescriptions/create	DOCTOR+
PUT	/api/prescriptions/update/{id}	DOCTOR+

Create body

```
{
  "medicalRecordId": 1,
  "patientId": 1,
  "doctorId": 1,
  "medicationName": "Amlodipine",
  "dosage": "5mg",
  "instructions": "Once daily in the morning"
}
```

5.14 Reschedule — /api/reschedule

Workflow: PATIENT creates request → ADMIN forwards → DOCTOR approves/rejects (or ADMIN rejects directly).

Method	Path	Auth	Notes
POST	/api/reschedule/request	PT/DR/AD	Body: { "appointmentId":N, "patientId":N, "requestedDate":"YYYY-MM-DD", "requestedTime
GET	/api/reschedule/admin/all	ADMIN	All requests
PUT	/api/reschedule/admin/forward/{id}	ADMIN	Body: { "adminNotes":"..." }; status → FORWARDED
PUT	/api/reschedule/admin/reject/{id}	ADMIN	Body: { "adminNotes":"..." }; status → REJECTED
GET	/api/reschedule/doctor/{doctorId}	DOCTOR+	Forwarded requests for doctor
PUT	/api/reschedule/doctor/approve/{id}	DOCTOR+	Body: { "doctorNotes":"..." }; status → ACCEPTED
PUT	/api/reschedule/doctor/reject/{id}	DOCTOR+	Body: { "doctorNotes":"..." }; status → REJECTED

status lifecycle: PENDING → FORWARDED → (ACCEPTED | REJECTED)

5.15 Telemedicine — /api/telemedicine

Method	Path	Auth	Notes
GET	/api/telemedicine/sessions	 DOCTOR+	Returns [{ id, doctor, patient, dept, duration, date, status }]
POST	/api/telemedicine/sessions/complete	 DOCTOR+	Body: { "appointmentId":N, "durationMinutes":25 } — closes the session; auto-bills

Video room URL is taken from appointment.sessionUrl , fallback https://meet.jit.si/mediconnect-{appointmentId} .

5.16 AI Assistant — /api/ai

POST /api/ai/chat  AUTH

Body

```
{
  "messages": [
    { "role": "user", "content": "What are the symptoms of hypertension?" }
  ],
  "systemPrompt": "You are MediConnect AI..."
}
```

- role per message ∈ user , assistant
- systemPrompt optional — server uses default if omitted

Response 200

```
{ "reply": "Common symptoms include headaches..." }
```

Backed by Google Gemini. Rate-limited by the free tier; avoid bulk load tests on this endpoint.

6. Suggested test scenarios

A minimum smoke suite the testing team can build out:

#	Scenario	Expected
1	POST /api/auth/login with seeded doctor creds	200 + token
2	Same, wrong password	401/403
3	GET /api/appointments/doctor/1 with no Authorization header	401
4	Same, with valid DOCTOR token	200, array
5	Patient token hitting GET /api/admin/stats	403
6	POST /api/appointments then GET /api/appointments/{id}	200/201 then 200 with same data
7	PATCH /api/lab-reports/{id}/result with DOCTOR token	403 (ADMIN only)
8	Same with ADMIN token	200
9	POST /api/auth/register with already-registered email	409
10	GET /api/hospitals with no token	200 (public)

7. Example: REST Assured login + protected call

```
import io.restassured.RestAssured;
import io.restassured.http.ContentType;
import static io.restassured.RestAssured.given;
import static org.hamcrest.Matchers.*;
import java.util.Map;

class SmokeTests {

    static String token;

    @BeforeAll
    static void login() {
        RestAssured.baseURI = "https://mediconnect-production-c233.up.railway.app";
        token = given()
            .contentType(ContentType.JSON)
            .body(Map.of("email", "arun.kumar@cgh.com",
                "password", "MediConnect@123"))
            .when()
            .post("/api/auth/login")
            .then()
            .statusCode(200)
            .extract().path("token");
    }

    @Test
    void getDoctorAppointments_returnsList() {
        given()
            .header("Authorization", "Bearer " + token)
            .when()
            .get("/api/appointments/doctor/1")
            .then()
            .statusCode(200)
            .body("$", isA(java.util.List.class));
    }

    @Test
    void patientHittingAdminEndpoint_isForbidden() {
        String patientToken = given()
            .contentType(ContentType.JSON)
            .body(Map.of("email", "rajesh.sharma@gmail.com",
                "password", "MediConnect@123"))
            .when().post("/api/auth/login")
            .then().extract().path("token");

        given()
            .header("Authorization", "Bearer " + patientToken)
            .when()
            .get("/api/admin/stats")
            .then()
            .statusCode(403);
    }
}
```

8. Notes for the testing team

1. **Cold starts.** Use a 30 s timeout. Consider a warm-up call before the suite runs.
2. **Shared DB.** The deployed API writes to a real MySQL. Plan destructive tests to clean up after themselves, or coordinate with the dev team for a fresh re-seed.

3. **Gemini quota.** `/api/ai/chat` has a small daily free-tier limit. Don't hammer it.
4. **WebSocket** endpoints (`/ws/**`) exist for realtime notifications but are out of scope for REST contract testing.
5. **Refresh tokens / logout** are not implemented — tokens just expire after 24 h.
6. **Date / time formats**
 - `LocalDate` → "YYYY-MM-DD"
 - `LocalTime` → "HH:mm:ss"
 - `LocalDateTime` → "YYYY-MM-DDTHH:mm:ss"
7. **Bug reports** — when filing, include: full request URL, method, headers (mask the token), body, response status, response body, and timestamp. Attach the seeded user used.

9. Quick reference — Postman / curl

Login & store token (bash)

```
TOKEN=$(curl -s -X POST https://mediconnect-production-c233.up.railway.app/api/auth/login \  
-H "Content-Type: application/json" \  
-d '{"email":"arun.kumar@cgh.com","password":"MediConnect@123"}' \  
| jq -r '.token')  
  
curl -H "Authorization: Bearer $TOKEN" \  
https://mediconnect-production-c233.up.railway.app/api/appointments/doctor/1
```

Login & store token (PowerShell)

```
$resp = Invoke-RestMethod -Method Post `\  
-Uri "https://mediconnect-production-c233.up.railway.app/api/auth/login" `\  
-ContentType "application/json" `\  
-Body '{"email":"arun.kumar@cgh.com","password":"MediConnect@123"}'  
  
$headers = @{ Authorization = "Bearer $($resp.token)" }  
Invoke-RestMethod -Uri "https://mediconnect-production-c233.up.railway.app/api/appointments/doctor/1" `\  
-Headers $headers
```